Audit model using controls from ISO/IEC 27002 for the information security of electronic voting based on IoT and Blockchain

Edson Paredes
Information Systems Engineering Program
Universidad Peruana de Ciencias Aplicadas
Lima, Perú
u201915575@upc.edu.pe

Marco Mendez
Information Systems Engineering Program
Universidad Peruana de Ciencias Aplicadas
Lima, Perú
u201720323@upc.edu.pe

Jymmy Dextre
Information Systems Engineering Program
Universidad Peruana de Ciencias Aplicadas
Lima, Perú
pcisjdex@upc.edu.pe

Abstract— **In recent years, significant progress has been made in the integration of technologies in voting systems with the aim of improving the transparency of the process. This study proposes an audit model based on the ISO/IEC 27002 standard to evaluate electronic voting systems that make use of Blockchain technology and the Internet of Things (IoT), with the aim of improving security in voting processes. To validate this model, an evaluation of the security control was carried out by applying this international standard to a voting system that integrates Blockchain and IoT. In our analysis of 6 security controls applied to the reality of electronic voting, the system passed all established tests; Therefore, it can be concluded that the risk of compromising system information has been significantly mitigated. This research contributes to the advancement of the security of electronic voting systems and provides a solid foundation for future developments in this field. The combination of emerging technologies and international standards promotes trust, security and therefore mitigates any risk of compromising an electronic voting system by following the best practices of the international standard ISO/IEC 27002.**

Keywords— Audit model, Security controls, University e-vote, IoT, Blockchain, ISO 27002

I. INTRODUCTION

Presential voting is the traditional method employed by many countries worldwide; however, this approach has been criticized for its potential susceptibility to disruptions such as adverse weather conditions, natural disasters, closures, or long queues at polling stations [1]. Failing to address this issue could result in existing electoral systems remaining vulnerable to electoral fraud and a lack of transparency in government elections [2]. Online voting systems must meet conditions such as eligibility, non-reusability, impartiality, and validity to be effective [4]. The significant risks of cyber-attacks and the limited scalability of such voting processes currently preclude their consideration for national elections [5]. It is crucial to establish reliable access control and authentication features in systems using IoT [6] and to differentiate between ideal and malicious IoT devices [7].

The adoption of Blockchain technology in a voting system ensures transparency, reliability, and traceability [8], safeguarding voter privacy [9] and enabling the audit of election results [10]. In Jordan, a system called BBVS, based on private and centralized Blockchain, has been implemented for the country's elections to enhance information security and transparency [11]. Estonia uses online voting to boost electoral participation, but challenges exist in ensuring fair and transparent democratic elections [3]. In various schools and businesses in Malaysia and India, there have been studies on implementing a Blockchain system integrated with an Android operating system for the deployment of an electronic voting system [12].

The controls of a standard are designed to safeguard data availability, confidentiality, and integrity to ensure information security in the organizational environment [13], thereby facilitating compliance with global security requirements in an organization [14]. While there are indeed voting system models based on Blockchain and IoT generated in Peru [15], the authors do not integrate these technologies and their implications with the controls of ISO/IEC 27002, which have individually contributed to improving security issues in the research.

Therefore, this article proposes an audit model based on the ISO/IEC 27002 standard to evaluate voting systems utilizing Blockchain and the Internet of Things (IoT) for information security in the voting process. This will be developed in three phases, involving the analysis of the technologies to be used (Blockchain and IoT), the design of the proposed architecture with the analyzed elements, and the validation of the developed architecture with security controls based on ISO/IEC 27002.

This document is divided into the following sections: Section 2 covers related works, Section 3 presents the audit model, Section 4 discusses validation, Section 5 outlines results, and finally, conclusions and future work are addressed in the last section.

II. RELATED WORK

Once technology began generating value on the planet, solutions aligning with the improvement of confidentiality, transparency, integrity, and availability of voting started to emerge. For this reason, studies will be presented to explore what has already been developed and what is innovative.

In [16], authors examined current electronic voting systems, focusing on Decentralized Applications (D-Apps) and different blockchain types. They proposed a comprehensive voting system framework, emphasizing security, advocating for restricted storage, and recommending cost-effective bytes1 and bytes32 due to their lower cost.

Similarly, [17] authors addressed privacy and anonymity challenges in elections, proposing a blockchain-based solution. They compared existing electronic voting solutions and suggested a scheme integrating two blockchains. They devised a process for vote transfer, decryption, result generation, and presented an architecture for information transfer.

979-8-3503-9547-1/23/$31.00 © 2023 IEEE

Lastly, in [12], authors developed a secure Android-based electronic voting app, implementing anti-phishing measures. They enhanced user experience, proposed an architecture focusing on presentation, business, and information layers in a mobile environment, connected to a remote infrastructure.

III. Electronic Voting Audit Model

The security audit model for electronic voting aims to ensure the integrity, confidentiality, and availability of information in the voting process. The goal is to mitigate the risks of vulnerabilities and cyber-attacks that could compromise the security and legitimacy of electoral results through security controls based on the ISO/IEC 27002 standard. For this reason, three main phases were developed to address this issue (see Fig. 1).

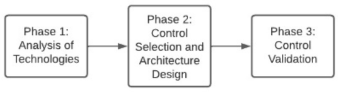

Fig. 1. In the figure, the phases for the creation of the audit model are depicted.

A. Phase 1: Analysis of Technologies

The purpose of this phase is to employ evaluation criteria that allow us to determine which Blockchain architecture and IoT device are most suitable for providing security, cost-effectiveness, interoperability, and applicability in the project context. Hence, the following activities were conducted: Comparison of Blockchain architectures, IoT devices and system voting models.

After completing a thorough evaluation of each Blockchain architecture, the conclusion has been reached to select Ethereum. This choice is based on its ability to meet the project's requirements in terms of speed, cost, and security. Regarding the IoT element, the decision has been made to use smartphones due to their compatibility with the required authentication and accessibility for electronic voting. Also, in our analysis of different voting system models, it became evident that none of them prioritize the enhancement of cybersecurity measures within the system.

B. Phase 2: Control Selection and Architecture Design

The goal of this phase is to analyze and manage the previously evaluated technologies to generate an architecture that meets high standards of availability, integrity, and confidentiality through the application of security controls.

The implementation of an electronic voting system poses significant security challenges. Our main objective is to develop an audit model applied to an electronic voting system to demonstrate its robustness and reliability. For this reason, 6 security controls were carefully selected from the 14 chapters of the ISO/IEC 27002 standard that were chosen for the risk they bring to an electoral process (Table I).

TABLE I. 6 Selected Controls of ISO/IEC 27002

N° Control	Control Objective
A.9.1.1	Access Control
A.9.3.1	Use of secret authentication information
A.10.1.1	Use of cryptographic controls
A.12.6.1	Management of technical vulnerabilities
A.12.7.1	Information audit controls
A.14.2.8	System security testing

In building an audit model, it's crucial to develop an architecture. This tool demonstrates a comprehensive strategy for evaluating technologies and their connections. The architecture incorporates User and Smartphone Layers, ensuring user participation, authentication, and authorization. The Blockchain Layer enhances voting transparency via transactions in the Smartphone Layer. The ISO/IEC 27002 Layer ensures security compliance, safeguarding system information. Together, this architecture provides a robust platform for electronic voting (see Fig. 2).

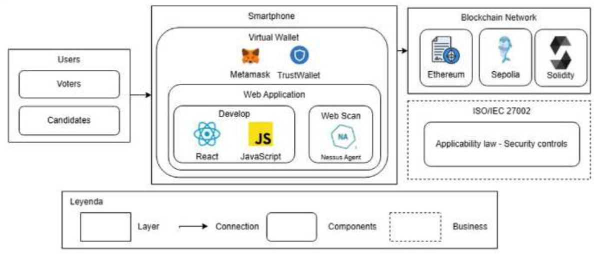

Fig. 2. Logical Architecture of the Audit Model.

C. Phase 3: Control Validation

The objective of this phase is to validate the 6 selected controls through a comprehensive evaluation of a Blockchain and IoT-based electronic voting system, with the aim of ensuring compliance with the security standards set by the ISO/IEC 27002 standard.

During this validation, audits and detailed reviews of the developed system are conducted to ensure it is free from vulnerabilities that could compromise the integrity, confidentiality, and availability of information. Compliance with these controls contributes to promoting transparency, reliability, and security in the Blockchain and IoT-based voting process.

IV. Validation

The evaluation of the audit model was conducted through the electronic voting system at the Peruvian University of Applied Sciences (UPC), located in the district of Surco, province of Lima, Peru. This process involved the selection of a delegate in a specific section of the course 'Project Workshop II,' in which 9 university students participated as voters. These voters received 0.001 Ethereum from the Sepolia test network in their Metamask wallets. Using these Ethereum addresses, they were able to cast their votes for their preferred candidate through the online electronic voting system. To validate the model, an audit of the system was performed with the selected controls from ISO/IEC 27002 (Table II).

TABLE II. Validation of Controls in the System

Control	Validation tools
Use of cryptographic controls	The web application Etherscan was used, which displays the blocks and transactions of Ethereum.
Management of technical vulnerabilities	The Tenable IO tool was utilized, install an agent on the asset to assess the vulnerabilities.
Access Control	The metamask API was used for user authentication, ensuring access control with security certifications.
Use of secret authentication information	The guidelines from the Metamask tool were used to create a secure password.

Control	Validation tools
System security testing	A robust procedure was used to carry out attacks, indentify vulnerabilities, and implement their mitigation.
Information audit controls	A table was used to document the approval of all security controls established for the Blockchain and IoT-based electronic voting system.

V. Results and Discussion

Audits were conducted based on the controls mentioned in Section IV, and the following results were obtained:

A. *Use of cryptographic controls*

In Table III, the compliance level of the cryptographic control criteria in the voting system is detailed, demonstrating a resulting enhancement in data confidentiality and integrity. Unlike other projects, this one stands out for its robust encryption, having implemented the ECDSA algorithm for digital signatures and KECCAK-256 for encryption using Solidity and the Ethereum cryptocurrency (Table III).

TABLE III. Use Of Cryptographic Controls

Cryptographic evaluation	Complies?
Encryption type	Yes, ECDSA and KECCAK-256 algorithm.
Smart Contract	Yes, the Solidity tool was used.
Connection to Blockchain	Yes, the Alchemy API was used.
Contract address	Yes, contract address: 0xB5B60f0766..14.

B. *Management of technical vulnerabilities*

In the system, a meticulous vulnerability scanning was conducted. The table presented below details the identified vulnerabilities and the corresponding corrections made in the operating system, resulting in early detection of potential threats, a reduction in risks through vulnerability mitigation, and a notable improvement in the overall integrity of the electronic voting system (Table IV).

TABLE IV. Management Of Technical Vulnerabilities

Description	VPR x Severity	Vulnerability State
Ruby regression (USN-6055-2)	Low	FIXED
TeX Live vulnerability (USN-6115-1)	Low	FIXED

C. *Access Control*

As a result, we achieve compliance with Metamask's access criteria to access the electronic voting system, ensuring robust protection against malicious activities and securing data integrity. Additionally, the key difference from other projects in terms of system access lies in the use of a specific cryptocurrency wallet, enabling the connection with the voting system and ensuring robust security (Table V).

TABLE V. Access Control

Access evaluation	Complies?
Wallet with web browser	Yes, the Metamask cryptocurrency wallet
Biometric authentication	Yes, fingerprint and facial verification
Secure API Key	Metamask on mobile phones and computers
Recovery phrase	Yes, Metamask requests a recovery phrase.

D. *Use of secret authentication information*

The guidelines provided by Metamask were followed for password creation, demonstrating a rigorous approach to safeguarding user accounts. Additionally, a table is presented detailing compliance with criteria for generating secure passwords, resulting in significant benefits such as robust system protection, prevention of potential attacks, and enhanced trust in user authentication (Table VI).

TABLE VI. Use of Secret Authentication Information

Password assessment	Complies?
8 to 12 characters	Metamask requests that length
Alphabetical, numerical and special data	Metamask requires users to include these types of data in their passwords.
Recovery phrase	Yes, Metamask asks to generate a phrase.

E. *System security testing*

Reviews were conducted for the detection and mitigation of vulnerabilities that compromise the system's security. Additionally, the following table shows the evaluated open ports in a specific environment as a result (Table VII).

TABLE VII. System Security Testing

Port	Status	Service	Review Date
902	Open	ISS-Realsecure SSL/Vmware-auth	10/09/2023

F. *Information audit controls*

After ensuring the implementation of security controls, they have been classified using the corresponding assessment table. As a result, a 100\% compliance with security controls was achieved, significantly contributing to strengthening the system's security in all aspects (Table VIII).

TABLE VIII. Information Audit Controls

Control	Approved?	Observations
Use of cryptographic controls	Yes	None
Management of technical vulnerabilities	Yes	None
Access Control	Yes	None
Use of secret authentication information	Yes	None
System security testing	Yes	None
Information audit controls	Yes	None

VI. Conclusions And Future Work

This study has allowed us to audit an Ethereum Blockchain-based electronic voting system and an IoT element, applying security controls aligned with ISO-IEC 27002 to provide confidence, security, and thus mitigate any risk of compromising an electronic voting system following the best practices of the international ISO/IEC 27002 standard.

The validation of the audit model based on an electronic voting system at a university allowed us to provide security, transparency, confidentiality, integrity, and availability in the information of the votes. Additionally, to verify the controls, tools such as Tenable IO were used to detect vulnerabilities in a system, EtherScan to review the details of an Ethereum address transaction, and Alchemy for event tracking.

As a result, we demonstrated compliance with the selected security controls from ISO 27002, showcasing a solid commitment to best practices, providing a strong foundation for maintaining a secure environment where critical information was adequately protected. This established an excellent level of security in the voting information. We contribute value to the cybersecurity domain by conducting audits on electronic voting systems, including those incorporating emerging technologies, where studies are currently lacking.

For future work, we plan to adjust our audit model to fit electronic voting systems in the realm of local government, such as municipalities. This will involve the integration of innovative technologies and the optimization of the Statement of Applicability (SOA) to effectively support elections of such magnitude. Within the current infrastructure of the electronic voting system, we face challenges such as managing the Ethereum address whitelist for voting in the local government sector, selecting relevant controls, standardizing tools, and determining specific controls to be applied to the SOA.

Acknowledgment

We express our gratitude to those who collaborated by being part of the experiment to validate the proposal, as well as to the Research Department of the Peruvian University of Applied Sciences for their support in providing us with the facilities for the research project.

References

[1] M.-V. Vladucu, Z. Dong, J. Medina, and R. Rojas-Cessa, "E-voting Meets Blockchain: A Survey," IEEE Access, 2023, doi: 10.1109/ACCESS.2017.DOI.

[2] M. S. Farooq, U. Iftikhar, and A. Khelifi, "A Framework to Make Voting System Transparent Using Blockchain Technology," IEEE Access, vol. 10, pp. 59959–59969, 2022, doi: 10.1109/ACCESS.2022.3180168.

[3] P. Ehin, M. Solvak, J. Willemson, and P. Vinkel, "Internet voting in Estonia 2005–2019: Evidence from eleven elections," Gov Inf Q, vol. 39, no. 4, Oct. 2022, doi: 10.1016/j.giq.2022.101718.

[4] U. Jafar, M. J. A. Aziz, and Z. Shukur, "Blockchain for Electronic Voting System—Review and Open Research Challenges," Sensors, vol. 21, no. 17, p. 5874, Aug. 2021, doi: 10.3390/s21175874.

[5] A. Benabdallah, A. Audras, L. Coudert, N. El Madhoun, and M. Badra, "Analysis of Blockchain Solutions for E-Voting: A Systematic Literature Review," IEEE Access, 2022, doi: 10.1109/ACCESS.2017.DOI.

[6] S. Uppuluri and G. Lakshmeeswari, "Secure user authentication and key agreement scheme for IoT device access control based smart home communications," Wireless Networks, Apr. 2022, doi: 10.1007/s11276-022-03197-1.

[7] G. Rathee, R. Iqbal, O. Waqar, and A. K. Bashir, "On the Design and Implementation of a Blockchain Enabled E-Voting Application within IoT-Oriented Smart Cities," IEEE Access, vol. 9, pp. 34165–34176, 2021, doi: 10.1109/ACCESS.2021.3061411.

[8] M. S. Farooq, U. Iftikhar, and A. Khelifi, "A Framework to Make Voting System Transparent Using Blockchain Technology," IEEE Access, vol. 10, pp. 59959–59969, 2022, doi: 10.1109/ACCESS.2022.3180168.

[9] X. Yang, X. Yi, S. Nepal, A. Kelarev, and F. Han, "Blockchain voting: Publicly verifiable online voting protocol without trusted tallying authorities," Future Generation Computer Systems, vol. 112, pp. 859–874, Nov. 2020, doi: 10.1016/j.future.2020.06.051.

[10] A. Poniszewska-Marańda, M. Pawlak, and J. Guziur, "Auditable blockchain voting system – the blockchain technology toward the electronic voting process," 2020.

[11] M. Malkawi, M. B. Yassein, and A. Bataineh, "Blockchain based voting system for Jordan parliament elections," International Journal of Electrical and Computer Engineering, vol. 11, no. 5, pp. 4325–4335, Oct. 2021, doi: 10.11591/ijece.v11i5.pp4325-4335.

[12] A. Sherine, G. Peter, A. A. Stonier, D. W. Leh Ping, K. Praghash, and V. Ganji, "Development of an Efficient and Secured E-Voting Mobile Application Using Android," *Mobile Information Systems*, vol. 2022, 2022, doi: 10.1155/2022/8705841.

[13] G. Culot, G. Nassimbeni, M. Podrecca, and M. Sartor, "The ISO/IEC 27001 information security management standard: literature review and theory-based research agenda," TQM Journal, vol. 33, no. 7. Emerald Group Holdings Ltd., pp. 76–105, Mar. 16, 2021. doi: 10.1108/TQM-09-2020-0202.

[14] J. N. Al-Karaki, A. Gawanmeh, and S. El-Yassami, "GoSafe: On the practical characterization of the overall security posture of an organization information system using smart auditing and ranking," Journal of King Saud University - Computer and Information Sciences, vol. 34, no. 6, pp. 3079–3095, Jun. 2022, doi: 10.1016/j.jksuci.2020.09.011.

[15] S. Andres and S. Herrera, "PONTIFICIA UNIVERSIDAD CATÓLICA DEL PERÚ FACULTAD DE CIENCIAS E INGENIERÍA Sistema de voto electrónico basado en blockchain Tesis Para optar por el Título de Ingeniero Informático que presenta el bachiller."

[16] C. Toma, M. Popa, C. Boja, C. Ciurea, and M. Doinea, "Secure and Anonymous Voting D-App with IoT Embedded Device Using Blockchain Technology," *Electronics (Switzerland),* vol. 11, no. 12, Jun. 2022, doi: 10.3390/electronics11121895.

[17] V. Neziri, I. Shabani, R. Dervishi, and B. Rexha, "Assuring Anonymity and Privacy in Electronic Voting with Distributed Technologies Based on Blockchain," *Applied Sciences (Switzerland)*, vol. 12, no. 11, Jun. 2022, doi: 10.3390/app12115477.